Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.12 / COMPANION WORKBOOK

Prove you can recover

Backups with custody, one rehearsed restore & the closing record

Close the Build path by proving the network can come back: scheduled directory and CA backups under ceremony-grade custody, policy, boundary, logs, and the living records in one hashed catalog, a timed restore rehearsal in isolation, and the recovery record that completes the Body of Evidence.

MATERIALS EDITION 1.2 / COURSE 1.12

Updated 8 October 2026 · sbd-prove-recovery

NAME _____ / DATE _____

START HERE / YOUR LEARNING PATH

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Decide what recovery must prove

02 Back up the directory, on schedule

03 Back up the CA, policy, boundary, and records

04 Carry the copies to the offline cabinet

05 Rehearse a real restore, in isolation

06 File the recovery record and close the path

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

© 2026 Secure By Design Team LLC.

Before you start

The model's final chapter: a network that cannot come back was never really built. This course backs up what matters — directory, certificate authority, policy, boundary, and the log record — proves one real restore in isolation, and files the tested-recovery evidence the authorization path expects.

Prerequisites

- ☐ Complete courses 1.1–1.11: the full network, its records, and the protected log archive all exist.
- ☐ Provision a protected backup volume on each server, written only by its backup job, an offline backup cabinet with removable media and a custody register, and an isolated recovery network segment (or host) for the restore rehearsal.
- ☐ Have the custody records handy: the Directory Services Restore Mode (DSRM) passwords from course 1.1 and the CA key protection decisions from course 1.4 — recovery is where those promises come due.

What this course builds

- Back up the directory, CA, policy, boundary, logs, and records into one verified catalog.
- Rehearse a real system state restore in isolation, measured against written objectives.
- File the tested-recovery record that completes the Body of Evidence for path 2.

Systems in scope

RECORD	YOUR OBSERVATION
SBD-DC01 — name, address, OS build	
SBD-DC02 — name, address, OS build	
SBD-SUBCA01 — name, address, OS build	
SBD-AUDIT01 — name, address, OS build	

© 2026 Secure By Design Team LLC.

LESSON 01 / ABOUT 20 MIN

Decide what recovery must prove

> **WHY THIS MATTERS** Recovery starts as a list of promises: which systems and records must be restorable, how old a restored copy may be, how long restoration may take — written as commitments the rest of the course exists to keep.

In this lesson you will

- Name the recovery set: what must come back, in what order.
- Set the recovery point and time objectives per item.
- Decide where backups live and who can touch them.

Follow the build

1. Write the recovery set in dependency order — the same order the path built it: the directory first (everything trusts it), then the CA's database and keys, Group Policy, the router configuration, the log archive, and the living records themselves (register, inventory, exception record).
2. Set the two numbers per item: how much history may be lost (recovery point) and how long restoration may take (recovery time) — lab-honest values you will actually measure against in lesson 5, not aspirations.
3. Decide backup placement: each server's protected backup volume is written only by the backup process and readable by the recovery role, and a custodian carries copies to the offline backup cabinet on media — the air-gapped network's version of an off-site copy. There is no network path to the cabinet.
4. Confirm the standing custody items: the DSRM passwords are sealed and findable, and the root CA's protected backup from the course 1.4 ceremony is accounted for — recovery depends on secrets that must exist before the bad day.

Check your result

```
# Capture the current protection state before this course changes it.
wbadmin get versions
Get-ChildItem E:\Backups -ErrorAction SilentlyContinue | Measure-Object   # this server's protected backup volume
```

> **WHAT SUCCESS LOOKS LIKE** The recovery set is ordered by dependency with point and time objectives per item, the backup placement and access rules are written, and the DSRM and root-key custody records check out.

Your record

Evidence to keep: Keep the recovery requirements sheet, the objectives table, the placement and access decisions, and the custody verification notes.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why does the directory lead the recovery order?

REMEMBER The recovery set is ordered by dependency, directory first. Point and time objectives exist to be measured, not admired. Backups get a protected home plus one offline, custody-tracked copy.

Microsoft · Active Directory forest recovery guide

NIST · SP 800-53 Rev. 5 security controls (CP family)

LESSON 02 / ABOUT 25 MIN

Back up the directory, on schedule

WHY THIS MATTERS System state from both controllers, on a schedule, to the protected target — plus the quiet feature that handles the most common 'disaster' of all: the Recycle Bin for deleted directory objects.

In this lesson you will

- Schedule system state backups on both domain controllers.
- Verify and catalog each backup with hashes.
- Enable the Active Directory Recycle Bin for object-level recovery.

Follow the build

1. Schedule Windows Server Backup jobs on SBD-DC01 and SBD-DC02 to each server's protected backup volume, including the system state and all critical volumes (wbadmin's -allCritical) so the same backup also supports a full server (bare-metal) recovery to different hardware — two controllers, two independent backups, because replication is availability and was never recovery (course 1.1's point, now kept).
2. After the first run, verify each backup's completion, record its version identifier, and hash the catalog entry into the evidence set — an unverified backup is a hope with a timestamp.
3. Enable the Active Directory Recycle Bin (a one-way, forest-level action from the Tier 0 seat, recorded as the change it is) so a deleted user or OU comes back intact without touching system state at all.
4. Write the restore decision tree: deleted object → Recycle Bin; corrupted DC on its own hardware → system state restore in DSRM (lesson 5's rehearsal); DC whose hardware is gone → full server (bare-metal) recovery from the critical-volumes backup; whole-forest loss → the Microsoft forest recovery guide, referenced and staged with the evidence rather than improvised on the day.

Check your result

```
wbadmin get versions
Get-ADOptionalFeature -Filter {Name -like 'Recycle Bin*'} | Select-Object Name,
EnabledScopes
Get-FileHash -Algorithm SHA256 C:\Evidence\recovery\backup-catalog.txt
```

WHAT SUCCESS LOOKS LIKE Both DCs show scheduled, completed system state versions on the protected target, the Recycle Bin reports an enabled scope, and the decision tree names the tool for each failure class.

Your record

Evidence to keep: Keep the backup schedules and version listings, the hashed catalog, the Recycle Bin enablement record, and the restore decision tree.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Both DCs replicate — why back up both?

> **REMEMBER** Two independent system state schedules, verified and cataloged. The Recycle Bin handles the everyday disaster in seconds. A decision tree matches each failure class to its tool.

Microsoft · Active Directory forest recovery guide

Microsoft · Wbadmin (Windows Server Backup)

Microsoft · AD forest recovery: perform a full server recovery

LESSON 03 / ABOUT 30 MIN

Back up the CA, policy, boundary, and records

> **WHY THIS MATTERS** The directory is not the only thing the network cannot re-derive: the issuing CA's database and key, the Group Policy set, the router's configuration, the log archive, and the living records each get their protected, cataloged copy.

In this lesson you will

- Back up the issuing CA's database and key to its protected backup volume under ceremony-grade protection.
- Refresh the Group Policy object (GPO) and router configuration backups into the protected set.
- Fold the log archive and living records into the same catalog.

Follow the build

1. Back up the issuing CA — database and private key — with certutil to SBD-SUBCA01's protected backup volume (E:\Backups in this sample), never to C:\Evidence: the private key is a secret, and secrets never go into evidence. Protect the key material to the same standard as the course 1.4 ceremony artifacts and record custody; only the backup's hashes and the custody record go into the evidence folder. The root's protected backup already exists from that ceremony and is verified, not duplicated, here.
2. Refresh the Group Policy backup (the course 1.3 Backup-GPO set, now the whole policy estate) and the router configuration export into the protected target, each hashed into the catalog.
3. Confirm the log archive's protection already satisfies this course — SBD-AUDIT01's hashed archives are themselves the record — and add the archive catalog to the recovery set so the evidence survives the systems it describes.
4. Export the living records — register, inventory, exception record, and this course's own sheets — into the set: a recovered network without its records would pass no assessment and teach the wrong lesson.

Check your result

```
# On SBD-SUBCA01: back up to the protected backup volume, never to the evidence folder.
certutil -backup E:\Backups\SBD-SUBCA01\ca-backup   # prompts for the password that
protects the exported key
# Only the hashes and the custody record go into evidence.
Get-ChildItem E:\Backups\SBD-SUBCA01\ca-backup -Recurse -File | Get-FileHash -Algorithm
SHA256 | Export-Csv C:\Evidence\recovery\ca-backup-hashes.csv -NoTypeInformation
Get-FileHash -Algorithm SHA256 C:\Evidence\recovery\gpo-backup\* | Select-Object -First 6
```

> **WHAT SUCCESS LOOKS LIKE** The CA backup sits on SBD-SUBCA01's protected backup volume with key custody recorded and only its hashes in evidence, the policy and router exports are current and hashed, and the catalog covers logs and living records alongside the systems.

Your record

Evidence to keep: Keep the CA backup's hash list and custody record (never the backup itself), the refreshed policy and router exports with hashes, and the complete recovery catalog.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why does the CA key backup get ceremony-grade handling?

> **REMEMBER** CA database and key: backed up to the protected volume, custody recorded, only hashes in evidence. Policy, boundary, logs, and records all live in one hashed catalog. The evidence now survives the systems it describes.

Microsoft · Wbadmin (Windows Server Backup)

Microsoft · Certutil reference (CA backup and restore)

LESSON 04 / ABOUT 20 MIN

Carry the copies to the offline cabinet

> **WHY THIS MATTERS** A backup that sits on the server it protects fails with it. Move a copy of each backup to the offline cabinet by hand, under the same custody rules as any media crossing a boundary, and keep the custody record that proves it.

In this lesson you will

- Define which custodian carries which backup, by tier.
- Transfer the copies to offline media with hashes and custody records.
- Prove a copy can be found, verified, and returned for a restore.

Follow the build

1. Assign custodians by tier: a Tier 0 custodian handles DC system state and the issuing CA's database and key backup; the audit custodian handles the log archive from SBD-AUDIT01; a server custodian handles member-server backups. No one carries a tier they do not hold.
2. For each copy, write the media ID, hash the backup on its protected volume, copy it to encrypted removable media, and verify the hash on the media before it leaves the room.
3. Carry the media to the offline backup cabinet and record the handoff in the custody register: who, what, when, the hashes, and the storage slot. This is the course 1.3 media procedure used for backups.
4. Pull one copy back as a test: find it from the register, verify its hash, and confirm it is readable. Lesson 5's rehearsal restores from a copy that has made this round trip.

Check your result

```
# Hash on the protected volume, then on the media.
Get-FileHash -Algorithm SHA256 E:\Backups\SBD-DC02\*.vhdx
Get-FileHash -Algorithm SHA256 F:\Media-0012\SBD-DC02\*.vhdx
```

> **WHAT SUCCESS LOOKS LIKE** Every item in the recovery set has an offline copy with matching hashes on the volume and the media, a custody entry with a named custodian of the right tier, and one copy has been retrieved and verified.

Your record

Evidence to keep: Keep the custodian assignments, the hash pairs, the custody register entries, and the retrieval test record.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Who carries the domain controllers' system-state backup to the cabinet?

> **REMEMBER** Custodians carry only the backups their tier allows. Every copy has matching hashes and a custody entry. A copy has been retrieved and verified before anyone needs it.

Microsoft · Wbadmin (Windows Server Backup)

NIST · SP 800-53 Rev. 5 security controls (CP family)

LESSON 05 / ABOUT 35 MIN

Rehearse a real restore, in isolation

> **WHY THIS MATTERS** One restore, actually performed: a domain controller's system state brought back on the isolated segment, timed against the objective, verified against the directory — plus the small restore everyone will someday need, from the Recycle Bin.

In this lesson you will

- Restore a DC's system state in Directory Services Restore Mode on the isolated recovery segment.
- Measure the restore against the time objective and verify directory health.
- Perform and record an object-level Recycle Bin restore.

Follow the build

1. Stage the rehearsal: the isolated recovery segment has no path to the production VLANs — a restored controller believing it is authoritative must never meet the live directory; that isolation rule is written before the restore starts.
2. Restore SBD-DC02 from the offline copy retrieved in lesson 4, timing the work from decision to directory-services-running against the lesson-1 objective. A system state restore needs the same server instance — use a copy of SBD-DC02's virtual machine attached only to the isolated segment — started in DSRM: bcdedit /set safeboot dsrepair, restart, and sign in with the DSRM password. Restoring to different hardware needs a full server (bare-metal) recovery from the critical-volumes backup instead.
3. Remove the DSRM boot setting (bcdedit /deletevalue safeboot) and restart normally, then verify the restored directory the course 1.1 way — services, shares, a directory query. Record what the rehearsal taught: steps that surprised you, the measured time, and the decision-tree updates; then tear the rehearsal down completely.
4. Back in production, run the everyday restore: delete a disposable test object, bring it back from the Recycle Bin with attributes intact, and file both rehearsals — the big one and the small one — as the tested-recovery evidence.

Check your result

```
# On the isolated copy of SBD-DC02: start in DSRM, then sign in with the DSRM password.
bcdedit /set safeboot dsrepair
shutdown -t 0 -r
wbadmin get versions -backupTarget:<media-volume> -machine:SBD-DC02
wbadmin start systemstaterecovery -version:<version-id> -backupTarget:<media-volume> -
machine:SBD-DC02
bcdedit /deletevalue safeboot   # then restart normally
Get-Service NTDS,DNS,Netlogon   # after restart, on the restored controller
Restore-ADObject -Identity <deleted-object-guid>   # production Recycle Bin rehearsal
```

> **WHAT SUCCESS LOOKS LIKE** The isolated restore ran in DSRM and reached a healthy directory within (or honestly against) the time objective, the DSRM boot setting is removed, the teardown is confirmed, and the production object restore returned the test object intact.

Your record

Evidence to keep: Keep the timed rehearsal log with its verification output, the lessons-learned and decision-tree updates, the teardown confirmation, and the object-restore record.

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why must the rehearsal segment be isolated from production?

> **REMEMBER** One real restore, isolated, timed, verified, and torn down. The measured number replaced the hoped-for one. The everyday restore is proven alongside the dramatic one.

Microsoft · Active Directory forest recovery guide

Microsoft · wbadmin start systemstaterecovery

Microsoft · Restore AD DS from backup (nonauthoritative restore)

Microsoft · Restart the domain controller in Directory Services Restore Mode locally

Microsoft · AD forest recovery: perform a full server recovery

LESSON 06 / ABOUT 20 MIN

File the recovery record and close the path

WHY THIS MATTERS The Build path ends the way it worked: owners, schedules, and evidence. The recovery record joins the living documents, the final scans snapshot the finished network, and the Body of Evidence is ready for the authorization courses to assemble.

In this lesson you will

- Assemble the tested-recovery record with owners and review dates.
- Run the closing scan snapshot across the finished network.
- Hand the complete evidence set to the authorization path.

Follow the build

1. Assemble the recovery record: the requirements and objectives, the backup catalog, both rehearsal results with the measured times, the decision tree, and a named owner with a scheduled next rehearsal — recovery is a practice with a calendar, not a binder.
2. Run the closing snapshot: the standing credentialed scan across every VLAN plus current Security Content Automation Protocol (SCAP) results per the cadence, triaged as always — the dated 'as-authorized' picture path 2 will reference.
3. Reconcile the three living records one final time — inventory against directory and leases, register against behavior, exception record against open findings — so the authorization path inherits agreement, not archaeology.
4. Write the Build path's closing note: what exists, where every record lives, and what is intentionally open — then start course 2.1, where this network stops being a project and becomes a system seeking authorization.

Check your result

```
Get-ChildItem C:\Evidence -Directory | Select-Object Name
Get-ChildItem C:\Evidence\recovery -Recurse | Measure-Object
Get-FileHash -Algorithm SHA256 C:\Evidence\recovery\recovery-record.pdf -ErrorAction
SilentlyContinue
```

WHAT SUCCESS LOOKS LIKE The recovery record is complete with an owner and next-rehearsal date, the closing snapshot is filed with triage, and all three living records reconcile cleanly into the handoff note.

Your record

Evidence to keep: Finish the checklist: the recovery record, the closing scan snapshot, the three reconciliations, and the Build path's closing note.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What makes recovery 'a practice with a calendar'?

> **REMEMBER** Recovery has an owner, a date, and a measured track record. The closing snapshot freezes the as-authorized picture. The Body of Evidence exists — path 2 assembles, it doesn't excavate.

Microsoft · Active Directory forest recovery guide

NIST · SP 800-53 Rev. 5 security controls (CP family)

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Decide what recovery must prove	☐ yes	
02 Back up the directory, on schedule	☐ yes	
03 Back up the CA, policy, boundary, and records	☐ yes	
04 Carry the copies to the offline cabinet	☐ yes	
05 Rehearse a real restore, in isolation	☐ yes	
06 File the recovery record and close the path	☐ yes	

Open items carried forward

Next in the learning path

That completes the Build the Network path. Continue with course 2.1 to carry this network — and its evidence — through the Risk Management Framework to an authorization decision.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.